SOFTWARE ENGINEER DOCUMENTATION

waapi — Source Code Documentation

Folder structure, packages, modules, migrations, routes, and test map for the waapi monorepo. Intended as a navigation guide for engineers and AI assistants.

pnpm workspace | Node 22+ | TypeScript | Drizzle / Fastify / Baileys

Document type: Source code documentation

Companion: Project Report PDF

Root: `waapi/` (git repo)

Tip: phase-4 (reports refresh after ff02a85)

PR: https://github.com/SyedIsmail-47/waapi/pull/4

Date: 22 October 2026

1. Repository root

```
waapi/
├── apps/                 # Deployable applications
│   ├── api/              # Fastify public + internal API
│   ├── worker/           # Baileys / fake session worker
│   ├── dashboard/        # React + Vite SPA
│   └── site/             # Static marketing site (Tailwind prerender)
├── packages/
│   ├── db/               # Drizzle schema + migrations
│   └── shared/           # Zod schemas, plans, brand, errors
├── deploy/               # nginx + logrotate (host install)
├── docs/                 # Runbook, design, reports
├── scripts/              # CLI, admin, preflight, backup, smoke
├── .github/workflows/    # CI: build + gitleaks + e2e
├── docker-compose*.yml
├── package.json          # Workspace scripts
├── pnpm-workspace.yaml
├── vitest.config.ts
├── eslint.config.js
└── .env.example
```

2. Workspace packages

Package	Name	Entry
`apps/api`	`@waapi/api`	`src/index.ts`, `src/app.ts`
`apps/worker`	`@waapi/worker`	`src/index.ts`
`apps/dashboard`	`@waapi/dashboard`	Vite `src/main.tsx`
`apps/site`	`@waapi/site`	`scripts/build.mjs` → `dist/`
`packages/db`	`@waapi/db`	`src/index.ts` (schema + client)
`packages/shared`	`@waapi/shared`	`src/index.ts` / `browser.ts`

3. Folder tree — apps/api

```
apps/api/src/
├── index.ts                # HTTP listen (public)
├── webhooks-main.ts        # Optional webhook delivery process
├── app.ts                  # buildApp / buildInternalApp (+ billing sweeper)
├── config.ts               # Zod env + production guards
├── types.ts
├── plugins/
│   ├── auth.ts             # JWT / PAT / session key
│   ├── error-handler.ts
│   ├── rate-limit.ts
│   └── request-id.ts
├── routes/
│   ├── v1/
│   │   ├── auth.ts         # register, login, me, PATs, password, delete
│   │   ├── sessions.ts
│   │   ├── send.ts
│   │   ├── messages.ts
│   │   ├── webhooks.ts
│   │   ├── billing.ts      # checkout + Paddle webhook (raw Buffer)
│   │   └── health.ts
│   ├── internal/admin.ts   # x-admin-secret ops + metrics + manual-review
│   ├── response-schemas.ts
│   └── route-schemas.test.ts
├── services/
│   ├── auth.ts
│   ├── sessions.ts
│   ├── send.ts / send-limits.ts
│   ├── messages.ts
│   ├── tokens.ts
│   ├── invites.ts
│   ├── email.ts
│   ├── disconnect-alerts.ts
│   ├── admin-ops.ts
│   ├── queues.ts
│   ├── retention.ts
│   ├── billing/            # provider, paddle, state-machine, sweeper
│   └── webhooks/           # sign, SSRF, deliveries
├── lib/                    # cookies, crypto, turnstile, phone, log-redact
├── workers/                # outbox-poller, webhook-delivery
└── *.integration.test.ts   # acceptance / matrix / tenant / billing
```

3.1 Public API surface (prefix `/api/v1`)

Area	Notable routes
Auth	`POST /auth/register`, `/login`, `/refresh`, `/logout`, `/verify-email`, `/forgot-password`, `/reset-password`, `/change-password`, `/delete-account`, `GET /auth/me`, `GET /auth/signup-config`, PAT CRUD
Sessions	create, get, list, PATCH rename, connect, disconnect, logout, delete, keys, status/QR
Send	`POST .../send-message` (text; idempotency-key; send-limit 429)
Messages	`GET /messages` metadata
Webhooks	endpoint upsert/delete/test; delivery listing
Billing	`GET /billing`, `POST /billing/checkout`, `POST /billing/webhooks/paddle`
Health	`/health`, `/ready`

3.2 Paddle webhook (N1)

Route registers a content-type parser with `parseAs: 'buffer'` for that path only. Signature: `Paddle-Signature` `ts` + one or more `h1` (rotation) over exactly `ts:rawBody`, constant-time compare, ±5 minute tolerance. Never re-stringify. Bad signature → generic 401. Duplicate event id → 200 no-op.

3.3 Internal admin (`:3001`, header `x-admin-secret`)

- `GET /internal/admin/users?q=`
- `POST .../accounts/:id/suspend|unsuspend|plan|revoke-keys`
- `POST .../sessions/:id/force-logout`
- `GET .../failing-webhooks`
- `POST .../invites`
- Manual review flagging (refunds / paused / mismatched events)
- Prometheus metrics

CLI wrapper: `scripts/admin-cli.ts` → `pnpm admin -- <cmd>`. Actions audit-logged; no message bodies.

4. Folder tree — apps/worker

```
apps/worker/src/
├── index.ts
├── config.ts
├── shutdown.ts
├── metrics.ts
├── logger.ts
├── baileys/
│   ├── types.ts             # WAClient interface
│   ├── create-client.ts     # baileys | fake
│   ├── baileys-client.ts
│   ├── fake-client.ts       # deterministic QR / send / inject
│   ├── fake-control-bus.ts
│   ├── auth-state.ts        # AES-GCM Postgres auth
│   └── wa-client.contract.test.ts
├── session/
│   ├── manager.ts           # connect, QR, reconnect, caps, PHONE_IN_USE
│   ├── reconnect.ts
│   ├── disconnect-reason.ts
│   └── disconnect-alerts.ts
├── jobs/
│   ├── send-text.ts
│   ├── session-commands.ts
│   └── queues.ts
├── redis/                   # lease, node-lock, pubsub, commands
├── crypto/                  # aes, key-ring
└── db/                      # sessions helpers, phone-in-use, tenant-isolation
```

Driver selection: `WA_DRIVER=baileys|fake`. Fake is for tests/smoke (`SMOKE_MODE` required in production if fake is set — production boot refuses fake).

5. Folder tree — apps/dashboard

```
apps/dashboard/src/
├── main.tsx / App routing
├── brand.ts                 # VITE_BRAND_NAME
├── pages/
│   ├── SignupPage.tsx       # invite + terms checkbox
│   ├── LoginPage.tsx
│   ├── VerifyEmailPage.tsx / ForgotPassword / ResetPassword
│   ├── SessionsPage.tsx / SessionDetailPage.tsx
│   ├── MessagesPage.tsx
│   ├── PatsPage.tsx
│   ├── SettingsPage.tsx     # password, resend verify, delete
│   └── BillingPage.tsx
├── components/              # ui + auth (Turnstile)
├── lib/
│   ├── api-client.ts        # CSRF header + refresh
│   └── friendly-errors.ts   # PHONE_IN_USE, billing, send-limit copy
└── …
apps/dashboard/e2e/
├── smoke.spec.ts
└── fake-driver.spec.ts
```

6. Folder tree — apps/site

```
apps/site/
├── scripts/build.mjs        # prerender HTML from plans + env placeholders
├── src/input.css            # Tailwind entry
├── tailwind.config.js
├── build.test.ts            # asserts DRAFT legal + disclaimer + pricing
├── placeholder-guard.test.ts
└── dist/                    # build output (gitignored) — CF Pages
```

Routes: `/`, `/pricing/`, `/docs/`, `/terms/`, `/privacy/`, `/refund/`, `/aup/`, `/contact/`.

Env at build: `BRAND_NAME`, `LEGAL_NAME`, `LEGAL_ADDRESS`, `MERCHANT_OF_RECORD`, `PUBLIC_APP_URL`, `CONTACT_EMAIL`.

7. packages/shared

```
packages/shared/src/
├── brand.ts                 # getBrandName, token prefixes, headers
├── plans.ts                 # PLANS, send limits / warm-up, PUBLIC_PLAN_CODES
├── constants.ts             # statuses, queues, CURRENT_TERMS_VERSION
├── errors.ts                # ERROR_CODES incl. BILLING_*, SESSION_SEND_LIMIT, PHONE_IN_USE
├── schemas/
│   ├── auth.ts              # registerBodySchema (acceptTerms: true)
│   ├── session.ts
│   ├── api.ts / commands.ts / events.ts
├── payload-crypto.ts
├── types.ts
├── index.ts                 # Node export
└── browser.ts               # Dashboard-safe export (no Node-only)
```

8. packages/db — schema & migrations

```
packages/db/
├── src/schema.ts            # drizzle tables
├── src/client.ts / migrate.ts
└── drizzle/
    ├── 0000_phase1.sql … 0007_…
    ├── 0008_invite_codes.sql
    ├── 0009_billing.sql
    ├── 0010_terms_accepted.sql
    ├── 0011_wp_n.sql
    └── meta/_journal.json
```

Migration	Adds
0000–0007	Core accounts/sessions/auth/webhooks/outbound/outbox
0008	`invite_codes`
0009	`subscriptions`, `billing_events`
0010	`users.terms_version`, `users.terms_accepted_at`
0011	`manual_review_*`, disconnect alert columns, `session_send_counters`

Rule: migrations are additive and sequentially numbered. Do not rewrite applied SQL.

9. scripts/

Script	Purpose
`cli.ts`	Dev session CLI
`admin-cli.ts`	Internal admin ops (incl. manual-review)
`preflight.ts`	Production env gate
`backup-pg.sh` / `restore-pg.sh`	age-encrypted dump ↔ restore
`seed.ts`	Local seed account
`smoke-prod.ts`	Prod-shaped smoke
`nginx-security-curl.sh`	Header/probe checks
`rate-limit-probe.ps1`	Live rate-limit probe
`ram-probe.ts`	In-memory session-slot RSS probe (results in runbook)
`build-review-packs.mjs`	Regenerate gitignored review packs (never commit packs)

10. deploy/

- `nginx.conf` — TLS with Cloudflare Origin CA; HSTS/CSP; CF IP `real_ip`; proxy `/api` → API, `/` → dashboard; `/internal` blocked
- `logrotate.waapi.conf` — sample for nginx + `/var/log/waapi`
- `nginx-security.test.ts` — config assertions

11. Cross-cutting concerns

11.1 Security

- Argon2id passwords; hashed tokens; AES-GCM auth state & outbox payloads

- Pino redaction paths for auth headers/cookies/tokens/passwords/text
- Turnstile on auth forms; rate limits (IP / failed auth / account / route)
- Webhook URL SSRF checks; signed outbound deliveries
- Gitleaks + Playwright e2e in CI; workflow default `permissions: contents: read`; no `pull_request_target`
- Preflight rejects placeholders and console email in prod
- Public tree: security-pass / Claude handoff removed (private ops pack only)

11.2 Multi-tenancy

- All session/message/webhook queries scoped by `account_id`
- Cross-account access → 404 (or 403 where policy says so)
- Tests: phase-2 integration, session-ux, worker tenant-isolation

11.3 Privacy logging rule

Do not put secrets, refresh tokens, PAT/session keys, or message bodies in logs or plaintext DB columns meant for ops. Encrypted blobs are OK; audit meta must stay metadata-only.

12. Test map (selected)

File	Covers
`phase-2-round3.integration.test.ts`	Route matrix (no 5xx)
`invite-gate.integration.test.ts`	WP-B signup modes
`terms-acceptance.integration.test.ts`	WP-J terms
`billing.integration.test.ts` + state-machine / webhook-replay / paddle-*	WP-F / N1–N3
`billing-enforcement-matrix.integration.test.ts`	N4
`auth-cookies-production.test.ts`	N5
`send-limits.test.ts` / `disconnect-alerts.test.ts` / `sweeper.test.ts`	WP-N core
`admin-ops.integration.test.ts`	WP-G
`account-lifecycle.integration.test.ts`	WP-D
`session-ux.integration.test.ts`	WP-E
`phone-in-use.test.ts`	PHONE_IN_USE mapping
`apps/site/build.test.ts` + placeholder-guard	Static site / WP-M
`scripts/preflight.test.ts` / backup-restore	WP-L
`e2e/smoke.spec.ts` + `fake-driver.spec.ts`	N6 Playwright
`wa-client.contract.test.ts`	Fake ↔ real driver contract

Last full suite: **306 passed | 2 skipped** (308). Skips: `backup-restore.test.ts` age/gzip roundtrip and live DB restore (`skipIf` tools/env).

Operator acceptance (runbook): phone send/receive, network drop, logout done; RAM table filled from `pnpm ram-probe` .

13. Config entry points

- API: `apps/api/src/config.ts` (`validateConfigEnv`)
- Worker: `apps/worker/src/config.ts`
- Example env: `.env.example`
- CI env: `.github/workflows/ci.yml` (build, gitleaks, e2e)

14. Suggested reading order (for Claude / new engineers)

1. `README.md` → `docs/runbook.md`
2. `packages/shared/src/plans.ts` + `schemas/auth.ts`
3. `packages/db/src/schema.ts` + drizzle journal through 0011
4. `apps/api/src/app.ts` → `routes/v1/*` → `services/billing/*`
5. `apps/worker/src/baileys/types.ts` → `session/manager.ts`
6. `docs/design/billing.md` + private ops pack (security triage, not published)
7. This PDF + Project Report PDF

Source paths are relative to the waapi repo root. Generated without embedding secrets. For behavioral status and gaps, see the Project Report PDF.